LAPORAN AUDIT KEAMANAN WEBSITE

Spencer Web Security Audit Tool

Target Website	iaccess.id
URL Lengkap	https://iaccess.id/
Tanggal Audit	21 May 2026, 12:00:31 WIB
Metode	OWASP Top 10 + CVSS Scoring
Tool	SpencerWeb v2.0
Durasi Scan	236.29 detik

SECURITY GRADE: F **SKOR: 0/100**

1. RINGKASAN EKSEKUTIF

Audit keamanan website **iaccess.id** telah dilakukan pada tanggal **21 May 2026, 12:00:31 WIB** menggunakan Spencer Web Security Audit Tool. Audit ini menggunakan metodologi OWASP Top 10 dengan sistem penilaian risiko CVSS yang disederhanakan menjadi grade A-F.

Berdasarkan 79 pengecekan keamanan yang dilakukan, sistem mendapat grade **F** dengan skor **0/100**. Ditemukan total **41 kerentanan** yang terdiri dari:

Severity	Jumlah	Dampak
CRITICAL	0	Risiko tertinggi, harus segera diperbaiki
HIGH	7	Risiko tinggi, perbaiki dalam waktu dekat
MEDIUM	10	Risiko sedang, jadwalkan perbaikan
LOW	24	Risiko rendah, perbaikan opsional

2. METODOLOGI AUDIT

Audit ini dilakukan menggunakan pendekatan **Black-box Testing** — auditor tidak memiliki akses ke source code maupun infrastruktur internal, dan hanya berinteraksi dengan target sebagaimana attacker dari luar.

Framework yang digunakan:
• **OWASP Top 10** — standar industri untuk web application security testing
• **OWASP Testing Guide v4** — panduan teknis pengujian per kategori
• **CVSS v3.1** — Common Vulnerability Scoring System untuk penilaian risiko

Module yang dijalankan:
1. HTTP Security Headers Audit (Passive)
2. SSL/TLS Certificate Audit (Passive)
3. Sensitive File Exposure Scan (Passive)
4. CMS Detection & Version Check (Passive)
5. WordPress Plugin & Theme Scanner (Passive)
6. SQL Injection Scanner — Error, Boolean, Time-based (Active)
7. Reflected XSS Scanner (Active)
8. Stored XSS Scanner (Active)
9. CSRF Protection Checker (Active)
10. Open Port Reconnaissance (Active)

3. TEMUAN KERENTANAN

Temuan #1: Strict-Transport-Security	HIGH
Deskripsi:	Memaksa browser selalu menggunakan HTTPS
Rekomendasi:	Tambahkan header: Strict-Transport-Security: max-age=31536000; includeSubDomains

Temuan #2: Content-Security-Policy	HIGH
Deskripsi:	Mencegah XSS dan injeksi konten berbahaya
Rekomendasi:	Tambahkan header CSP yang sesuai. Minimal: Content-Security-Policy: default-src 'self'

Temuan #3: File: /phpmyadmin/	HIGH
Deskripsi:	EXPOSED! phpMyAdmin terdeteksi — akses langsung ke manajemen database (HTTP 200, 20000 bytes)
Rekomendasi:	Hapus phpMyAdmin dari production atau batasi akses via IP allowlist

Temuan #4: HTTP Method: PUT	HIGH
Deskripsi:	PUT method diterima server (HTTP 200) — File upload/overwrite — attacker bisa upload webshell atau overwrite file
Rekomendasi:	Disable PUT method kecuali diperlukan untuk API (dan lindungi dengan autentikasi)

Temuan #5: HTTP Method: DELETE	HIGH
Deskripsi:	DELETE method diterima server (HTTP 200) — File deletion — attacker bisa menghapus file di server
Rekomendasi:	Disable DELETE method kecuali diperlukan untuk API

Temuan #6: Directory: /phpmyadmin	HIGH
Deskripsi:	Path /phpmyadmin accessible (HTTP 301, 323 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #7: Directory: /phpmyadmin/	HIGH
Deskripsi:	Path /phpmyadmin/ accessible (HTTP 200, 20000 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #8: X-Frame-Options	MEDIUM
Deskripsi:	Mencegah clickjacking via iframe
Rekomendasi:	Tambahkan header: X-Frame-Options: DENY atau SAMEORIGIN

Temuan #9: X-Content-Type-Options	MEDIUM
Deskripsi:	Mencegah MIME-type sniffing
Rekomendasi:	Tambahkan header: X-Content-Type-Options: nosniff

Temuan #10: XML-RPC Endpoint	MEDIUM
Deskripsi:	xmlrpc.php aktif — bisa disalahgunakan untuk brute force dan DDoS amplification
Rekomendasi:	Disable XML-RPC jika tidak digunakan, atau batasi aksesnya

Temuan #11: User Enumeration	MEDIUM
Deskripsi:	Username admin teridentifikasi: 'hylmimuhammadfiarymahdi' via /?author=1
Rekomendasi:	Disable user enumeration via rewrite rules atau plugin keamanan. Hindari menggunakan username 'admin'.

Temuan #12: REST API User Enumeration	MEDIUM
Deskripsi:	REST API /wp-json/wp/v2/users mengekspos daftar user — attacker bisa enumerate username dengan mudah
Rekomendasi:	Disable atau batasi akses ke REST API users endpoint. Pakai plugin seperti Disable REST API atau filter di functions.php

Temuan #13: Clickjacking: /	MEDIUM
Deskripsi:	Halaman bisa di-embed dalam iframe (clickjacking). Missing: X-Frame-Options, CSP frame-ancestors. Attacker bisa overlay halaman ini dengan UI palsu.
Rekomendasi:	Tambahkan X-Frame-Options: DENY (atau SAMEORIGIN) DAN Content-Security-Policy: frame-ancestors 'self'

Temuan #14: Clickjacking: /profil/	MEDIUM
Deskripsi:	Halaman bisa di-embed dalam iframe (clickjacking). Missing: X-Frame-Options, CSP frame-ancestors. Attacker bisa overlay halaman ini dengan UI palsu.
Rekomendasi:	Tambahkan X-Frame-Options: DENY (atau SAMEORIGIN) DAN Content-Security-Policy: frame-ancestors 'self'

Temuan #15: Clickjacking: /produk/	MEDIUM
Deskripsi:	Halaman bisa di-embed dalam iframe (clickjacking). Missing: X-Frame-Options, CSP frame-ancestors. Attacker bisa overlay halaman ini dengan UI palsu.
Rekomendasi:	Tambahkan X-Frame-Options: DENY (atau SAMEORIGIN) DAN Content-Security-Policy: frame-ancestors 'self'

Temuan #16: Clickjacking: /portofolio/	MEDIUM
Deskripsi:	Halaman bisa di-embed dalam iframe (clickjacking). Missing: X-Frame-Options, CSP frame-ancestors. Attacker bisa overlay halaman ini dengan UI palsu.
Rekomendasi:	Tambahkan X-Frame-Options: DENY (atau SAMEORIGIN) DAN Content-Security-Policy: frame-ancestors 'self'

Temuan #17: Clickjacking: /berita/	MEDIUM
Deskripsi:	Halaman bisa di-embed dalam iframe (clickjacking). Missing: X-Frame-Options, CSP frame-ancestors. Attacker bisa overlay halaman ini dengan UI palsu.
Rekomendasi:	Tambahkan X-Frame-Options: DENY (atau SAMEORIGIN) DAN Content-Security-Policy: frame-ancestors 'self'

Temuan #18: X-XSS-Protection	LOW
Deskripsi:	Mengaktifkan filter XSS bawaan browser (legacy)
Rekomendasi:	Tambahkan header: X-XSS-Protection: 1; mode=block (atau gunakan CSP sebagai pengganti)

Temuan #19: Referrer-Policy	LOW
Deskripsi:	Mengontrol informasi referrer yang dikirim browser
Rekomendasi:	Tambahkan header: Referrer-Policy: strict-origin-when-cross-origin

Temuan #20: Permissions-Policy	LOW
Deskripsi:	Mengontrol akses fitur browser (kamera, mikrofon, geolokasi)
Rekomendasi:	Tambahkan header: Permissions-Policy: geolocation=(), camera=(), microphone=()

Temuan #21: Server (Info Leak)	LOW
Deskripsi:	Terdeteksi: cloudflare — Membocorkan versi web server (misal: Apache/2.4.41)
Rekomendasi:	Sembunyikan atau hapus header Server dari response

Temuan #22: Info Disclosure: /readme.html	LOW
Deskripsi:	File '/readme.html' accessible — membocorkan informasi versi WordPress
Rekomendasi:	Blokir akses ke /readme.html via konfigurasi web server

Temuan #23: Info Disclosure: Elementor readme.txt	LOW
Deskripsi:	File readme.txt plugin Elementor accessible — membocorkan versi plugin
Rekomendasi:	Blokir akses ke /wp-content/plugins/elementor/readme.txt

Temuan #24: Info Disclosure: LiteSpeed Cache readme.txt	LOW
Deskripsi:	File readme.txt plugin LiteSpeed Cache accessible — membocorkan versi plugin
Rekomendasi:	Blokir akses ke /wp-content/plugins/litespeed-cache/readme.txt

Temuan #25: Info Disclosure: Theme style.css	LOW
Deskripsi:	File style.css theme accessible — membocorkan nama dan versi theme
Rekomendasi:	Blokir akses langsung ke style.css theme

Temuan #26: Directory: /admin/index.php	LOW
Deskripsi:	Path /admin/index.php accessible (HTTP 301, 0 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #27: Directory: /admin/	LOW
Deskripsi:	Path /admin/ accessible (HTTP 302, 0 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #28: Directory: /admin	LOW
Deskripsi:	Path /admin accessible (HTTP 302, 0 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #29: Directory: /dashboard	LOW
Deskripsi:	Path /dashboard accessible (HTTP 302, 0 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #30: Directory: /login	LOW
Deskripsi:	Path /login accessible (HTTP 302, 0 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #31: Directory: /wp-admin	LOW
Deskripsi:	Path /wp-admin accessible (HTTP 301, 321 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #32: Directory: /wp-content/uploads	LOW
Deskripsi:	Path /wp-content/uploads accessible (HTTP 301, 331 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #33: Directory: /wp-login.php	LOW
Deskripsi:	Path /wp-login.php accessible (HTTP 302, 0 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #34: Directory: /wp-json	LOW
Deskripsi:	Path /wp-json accessible (HTTP 200, 245443 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #35: Directory: /administrator/index.php	LOW
Deskripsi:	Path /administrator/index.php accessible (HTTP 301, 0 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #36: Directory: /readme.html	LOW
Deskripsi:	Path /readme.html accessible (HTTP 200, 7425 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #37: Directory: /robots.txt	LOW
Deskripsi:	Path /robots.txt accessible (HTTP 200, 114 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #38: Directory: /sitemap_index.xml	LOW
Deskripsi:	Path /sitemap_index.xml accessible (HTTP 200, 637 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #39: Directory: /wp-cron.php	LOW
Deskripsi:	Path /wp-cron.php accessible (HTTP 200, 0 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #40: security.txt (missing)	LOW
Deskripsi:	security.txt tidak ditemukan — best practice adalah menyediakan file ini agar security researcher tahu cara melaporkan kerentanan
Rekomendasi:	Buat file /.well-known/security.txt sesuai RFC 9116. Minimal berisi Contact: dan Expires: fields.

Temuan #41: robots.txt (info disclosure)	LOW
Deskripsi:	robots.txt mengexpose 1 path sensitif: /wp-admin/. Attacker bisa menggunakan ini sebagai peta untuk menemukan halaman tersembunyi.
Rekomendasi:	Pertimbangkan untuk tidak mendaftarkan path sensitif di robots.txt. Gunakan autentikasi sebagai proteksi utama, bukan security by obscurity.

4. DETAIL HASIL PER MODULE

Module 1 — HTTP Security Headers

Passed: **2** | Failed: **8** | Total: **10**

Check	Severity
Strict-Transport-Security	HIGH
Content-Security-Policy	HIGH
X-Frame-Options	MEDIUM
X-Content-Type-Options	MEDIUM
X-XSS-Protection	LOW
Referrer-Policy	LOW
Permissions-Policy	LOW
Server (Info Leak)	LOW

Module 2 — SSL/TLS Certificate

Passed: **6** | Failed: **0** | Total: **6**

Module 3 — Sensitive File Exposure

Passed: **34** | Failed: **1** | Total: **35**

Check	Severity
File: /phpmyadmin/	HIGH

Module 4 — CMS Detection

Passed: **2** | Failed: **1** | Total: **3**

Check	Severity
Info Disclosure: /readme.html	LOW

Module 5 — WordPress Plugin Scanner

Passed: **2** | Failed: **6** | Total: **8**

Check	Severity
Info Disclosure: Elementor readme.txt	LOW
Info Disclosure: LiteSpeed Cache readme.txt	LOW
Info Disclosure: Theme style.css	LOW
XML-RPC Endpoint	MEDIUM
User Enumeration	MEDIUM
REST API User Enumeration	MEDIUM

Module 6 — Advanced SQL Injection

Passed: **1** | Failed: **0** | Total: **1**

Module 7 — Reflected XSS

Passed: **1** | Failed: **0** | Total: **1**

Module 9 — CSRF Protection

Passed: **5** | Failed: **0** | Total: **5**

Module 10 — Port Reconnaissance

Passed: **4** | Failed: **0** | Total: **4**

5. KESIMPULAN DAN SARAN PRIORITAS

Berdasarkan hasil audit, website **iaccess.id** memiliki **0 kerentanan CRITICAL** dan **7 kerentanan HIGH** yang memerlukan perhatian segera.

Saran prioritas perbaikan:

1. [HIGH] Strict-Transport-Security
Tambahkan header: Strict-Transport-Security: max-age=31536000; includeSubDomains

2. [HIGH] Content-Security-Policy
Tambahkan header CSP yang sesuai. Minimal: Content-Security-Policy: default-src 'self'

3. [HIGH] File: /phpmyadmin/
Hapus phpMyAdmin dari production atau batasi akses via IP allowlist

4. [HIGH] HTTP Method: PUT
Disable PUT method kecuali diperlukan untuk API (dan lindungi dengan autentikasi)

5. [HIGH] HTTP Method: DELETE
Disable DELETE method kecuali diperlukan untuk API

DISCLAIMER

Laporan ini dihasilkan secara otomatis oleh Spencer Web Security Audit Tool. Audit dilakukan pada waktu dan kondisi tertentu; kondisi keamanan website dapat berubah seiring waktu. Hasil audit ini hanya mencakup parameter yang diuji oleh tool dan tidak menggantikan audit keamanan manual oleh professional security expert. Beberapa temuan automated scanner dapat berupa false positive dan harus diverifikasi secara manual sebelum tindakan perbaikan diambil.

Generated by Spencer v2.0 — 21 May 2026